AUDITORÍA

DE SEGURIDAD WEB -INSTITUTO ENCINAS



https://eespencinas.edu.pe

AUSENCIA DE SECURITY HEADERS

Hallazgo Principal #1

Al analizar los encabezados de respuesta HTTP de eespencinas.edu.pe, se observa la falta de cabeceras de protección clave como Content-Security-Policy y X-Frame-Options

- **Riesgo:** El navegador no impone restricciones sobre la carga de scripts externos.
- **Exposición:** Permite la incrustación no autorizada del portal en marcos flotantes.

MATRIZ DE VULNERABILIDADES

Resumen del informe de seguridad

F

Sitio:	https://eespencinas.edu.pe/
Dirección IP:	142.4.206.237
Hora de presentación:	27 ago. 2026 15:47:25 UTC
Encabezados:	✖ Seguridad estricta en el transporte ✖ Política de seguridad de contenido ✖ Opciones de marco X ✖ X-Content-Type-Options ✖ Política de referencia ✖ Política de permisos
Avanzado:	¡Ay! Deberías mejorar tu seguridad de inmediato: **Comienza ahora**

Encabezados faltantes

Seguridad estricta en el transporte	HTTP Strict Transport Security es una excelente función para implementar en su sitio web y fortalece la implementación de TLS al lograr que el agente de usuario fuerce el uso de HTTPS. Valor recomendado: "Strict-Transport-Security: max-age=31536000; includeSubDomains".
Política de seguridad de contenido	La Política de Seguridad de Contenido es una medida eficaz para proteger su sitio web de ataques XSS. Al incluir en la lista blanca las fuentes de contenido aprobado, puede evitar que el navegador cargue recursos maliciosos.
Opciones de marco X	X-Frame-Options le indica al navegador si desea permitir que su sitio se muestre en un marco o no. Al impedir que un navegador muestre su sitio en un marco, puede protegerse contra ataques como el clickjacking. Valor recomendado: "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options impide que un navegador intente detectar el tipo MIME del contenido y lo obliga a mantener el tipo de contenido declarado. El único valor válido para este encabezado es "X-Content-Type-Options: nosniff".
Política de referencia	La política de referencia (Referrer Policy) es un nuevo encabezado que permite a un sitio controlar cuánta información incluye el navegador al navegar fuera de un documento, y debería ser configurada por todos los sitios.
Política de permisos	La política de permisos es un nuevo encabezado que permite a un sitio controlar qué funciones y API se pueden utilizar en el navegador.

MODELADO DE AMENAZAS

Inyección XSS

Ataque: Ejecución de JavaScript no autorizado mediante campos de texto sin sanear en el portal web

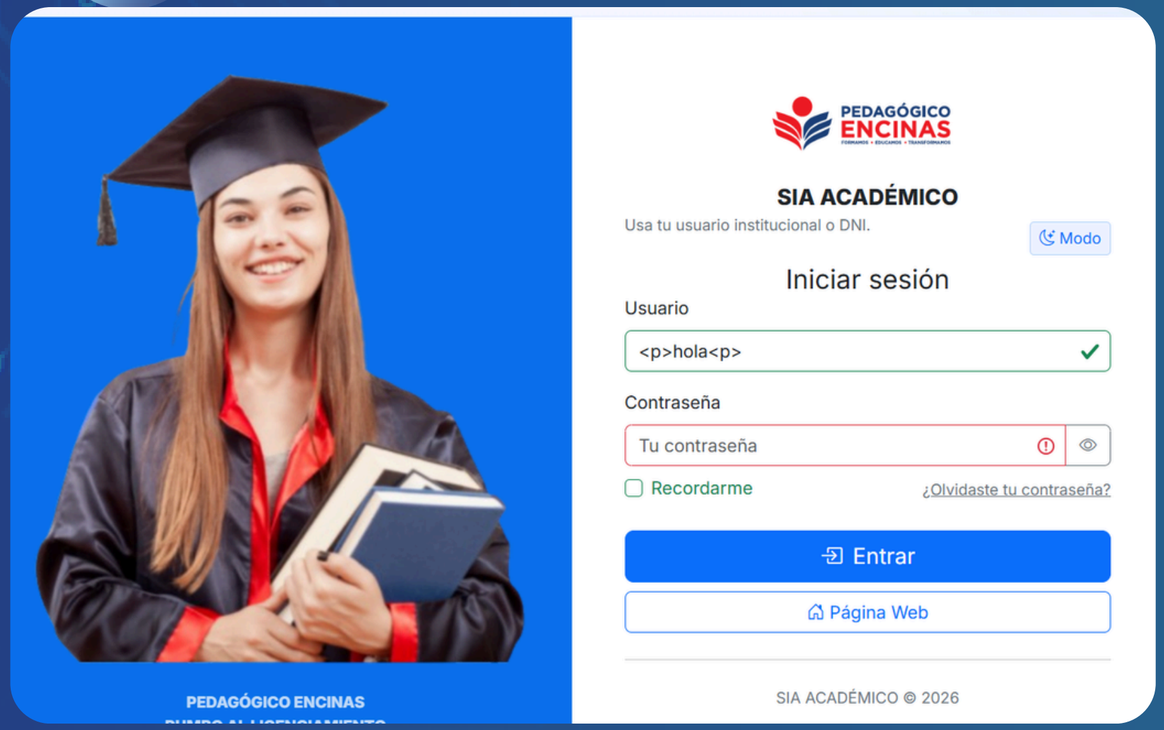
Clickhacking

Ataque: Superposición del portal institucional en una web maliciosa para engañar al usuario final

Hacking de Sesión

Ataque: Extracción de tokens de autenticación debido a cookies sin atributos de protección elevados.

EXPOSICIÓN EN FORMULARIOS WEB



Formularios de Consulta Académica

Los formularios que procesan consultas o registros de estudiantes deben validar rigurosamente la entrada de datos. Si el servidor no filtra etiquetas de código ni comillas, la base de datos queda expuesta a Inyecciones SQL o filtración de información confidencial.

IMPACTO INSTITUCIONAL

Compromiso de Datos Académicos:

Acceso no autorizado a registros de estudiantes, notas y expedientes administrativos institucionales.

Alteración de Contenido (Defacement):

Modificación visual del sitio web oficial con mensajes no autorizados, dañando el prestigio de la EESP.

Suplantación de Identidad:

Redirección de estudiantes a páginas falsas de inicio de sesión para el robo de credenciales.

Sanciones Administrativas:

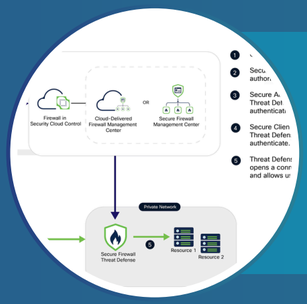
Incumplimiento de las normativas vigentes sobre protección de datos personales.

ESTRATEGIAS DE MITIGACIÓN



1. Sanitización de Código

Sanitización de CódigoUso de sentencias preparadas (PDO) y limpieza estricta de variables de entrada en el servidor.



2. Inyección de Headers

Configuración del archivo .htaccess o NGINX para emitir cabeceras de seguridad estrictas.



3. Protección de Cookies

Activación de parámetros Secure, HttpOnly y SameSite=Strict en sesiones.

GRACIAS
POR SU ATENCIÓN